

Reporte Ejecutivo de Gestión de Riesgos

Clínica Privada — Preparado para el Directorio — Elaborado con SimpleRisk — Septiembre 2026

Resumen Ejecutivo

Como parte del programa de gestión de riesgos de la organización, se realizó un relevamiento inicial de riesgos de seguridad de la información sobre los sistemas críticos de la clínica: historias clínicas electrónicas (HCE), facturación y datos de obras sociales. Se identificaron y evaluaron **7 riesgos** específicos del contexto asistencial, utilizando una matriz de probabilidad e impacto (escala 1–5) justificada con criterio profesional y fuentes del sector, incluyendo el informe Verizon DBIR 2026. El presente documento resume los hallazgos, prioriza los riesgos de mayor severidad y detalla el estado de los planes de acción en curso.

Analogía de referencia: así como el lobo feroz representó una amenaza externa persistente para Caperucita Roja — que confió en una apariencia inofensiva para acceder a un entorno protegido — los actores de amenaza actuales (phishing, ransomware) explotan la confianza del personal para vulnerar los sistemas de la clínica desde afuera.

Top 5 Riesgos por Nivel

ID	Riesgo	Prob.	Imp.	Valor	Nivel
R2	Ransomware en servidor de facturación y HCE	4	5	20	Crítico
R4	Phishing dirigido a personal administrativo	4	4	16	Crítico
R1	Filtración de HCE por acceso indebido de personal	3	5	15	Alto
R3	Caída del sistema en horario de atención	3	4	12	Alto
R6	Backups sin cifrar y sin pruebas de restauración	3	4	12	Alto

Los dos riesgos de nivel Crítico (ransomware y phishing) concentran el mayor peligro potencial para la continuidad operativa y la confidencialidad de los datos de pacientes, y son los priorizados en los planes de acción en curso.

Estado de los Planes de Acción

Riesgo asociado	Plan de acción	Responsable	Presupuesto	Vencimiento	Estado
R2 Ransomware	Backups offline + segmentación de red + capacitación	Enc. de TI	\$800.000	60 días	No iniciado
R4 Phishing	Capacitación anti-phishing + MFA	Seg. Inf. / RRHH	\$300.000	45 días	No iniciado
R1 Filtración HCE	Control de acceso por roles (RBAC) + auditoría	Resp. Seguridad	\$500.000	90 días	No iniciado

Analogía de tratamiento en capas: tal como los tres cerditos aprendieron que solo la casa de ladrillo —construida con más esfuerzo y planificación— resistió al lobo, la estrategia de tratamiento propuesta combina múltiples capas de defensa (técnica, de proceso y de concientización) en lugar de depender de un único control. Ningún plan aislado (paja o madera) es suficiente frente a amenazas persistentes: se requiere la combinación de backups, segmentación, control de accesos y capacitación del personal.

Recomendaciones Prioritarias

- Priorizar la implementación de backups offline verificados y la segmentación de red antes de fin de año, dado que el riesgo de ransomware es el de mayor severidad identificado.
- Extender la autenticación multifactor (MFA) a todas las cuentas con acceso a datos de pacientes, no solo a las de mayor exposición.
- Formalizar un cronograma de capacitación periódica en concientización de seguridad para todo el personal, no solo administrativo.

- Establecer una revisión trimestral de permisos de acceso al sistema de HCE una vez implementado el esquema de control de acceso basado en roles (RBAC).
- Por consideraciones de continuidad operativa y protección física de la infraestructura, los centros de datos y racks de servidores no deben ubicarse junto a cocinas ni debajo de instalaciones con piletas o cañerías de agua, dado el riesgo combinado de incendio e inundación sobre equipamiento crítico.